NUNMATHI

AI-Powered IPsec VPN Protocol Analyzer and Security Assessment Framework

Passive, key-less assessment of IPsec tunnels through protocol inference, ESP cipher geometry and explainable machine learning

Problem Statement ID:	SIH26160
Problem Statement Title:	AI-Powered IPsec VPN Protocol Analyzer and Security Assessment Framework
Theme:	Blockchain & Cybersecurity
PS Category:	Software
Nodal Organization:	National Technical Research Organisation (NTRO)
Team ID:	135221
Team Name:	Bharat-GenNXT
Solution Name:	NUNMATHI: passive IPsec VPN analyzer (desktop application, v1.2.0)

---

1. Introduction

1.1 Background

IPsec VPNs carry the most sensitive traffic of government departments, defence networks, banks and critical-infrastructure operators: site-to-site links between offices, remote-access tunnels for field staff, and management planes of industrial control systems. The security of such a tunnel depends on dozens of negotiated parameters (IKE version and mode, Diffie-Hellman group, encryption and integrity transforms, Perfect Forward Secrecy, SA lifetimes, NAT traversal and fragmentation). A single legacy choice such as IKEv1 Aggressive Mode with a pre-shared key, a 1024-bit MODP group or ESP-NULL silently reduces an encrypted link to one that can be cracked offline or read in cleartext.

These parameters are fixed in device configuration files spread across many vendors, and they are rarely audited once a tunnel is up. Auditors often have no access to the gateways or their keys and can only observe packets on the wire. Existing tools such as Wireshark dissect individual packets but do not turn them into a security verdict, and vulnerability scanners actively probe the gateway, which is often not allowed on production links.

1.2 Motivation

NTRO's problem statement asks for an analyzer that can assess IPsec VPN deployments from traffic alone, identify weak cryptography and misconfigurations, characterise what the encrypted traffic still reveals, and report in a form that both executives and engineers can act on. The motivation for **NUNMATHI** is to give an auditor a single, offline-capable desktop application that:

- **Works without keys:** draws every conclusion from cleartext IKE fields and from ESP packet lengths and timings, so it can be used on any capture, including third-party links.
- **Is explainable:** every alert carries a rule ID, risk, confidence, evidence, solution and standard references, in the familiar OWASP ZAP style.
- **Closes the loop:** a What-If digital twin shows the grade after a proposed change and emits ready-to-apply strongSwan, libreswan and Cisco IOS configuration.
- **Is deployable in air-gapped labs:** a standalone native application for Windows and Debian/Ubuntu, with no web server, no cloud service and no open network port.

2. Problem Statement

Organisations run large IPsec estates whose real security posture is unknown. The specific failure modes that NUNMATHI addresses are:

- **Legacy key exchange:** IKEv1, Aggressive Mode with PSK (offline dictionary attack on HASH_R), MODP-768/1024/1536 groups below 112-bit security.
- **Weak or missing encryption:** ESP-NULL (integrity only), 64-bit block ciphers such as 3DES vulnerable to Sweet32, MD5/SHA-1 integrity.
- **No forward secrecy:** Child SA rekeys without a fresh key exchange, so one compromised IKE SA exposes every Child SA.
- **Over-long lifetimes:** keys that stay in use for many hours and protect large volumes of data.
- **Denial of service:** half-open IKE_SA_INIT floods against responders without cookies or rate limiting.
- **Metadata leakage:** even with strong encryption, packet sizes and timings reveal whether a tunnel carries voice, video, web, chat or e-mail.
- **Quantum readiness:** no visibility into whether hybrid post-quantum key exchange (RFC 9370 with ML-KEM) is in use.
- **No actionable output:** packet dissectors show fields, not verdicts; results are not in a form that SOC tooling (SIEM/SOAR) or management can consume.

3. Research Review & Fundamentals

3.1 IPsec Protocol Suite

IPsec consists of two layers. **IKE** (Internet Key Exchange, UDP 500/4500) authenticates the peers and negotiates algorithms and keys; its first exchange (IKE_SA_INIT in IKEv2, Main or Aggressive Mode in IKEv1) is sent in cleartext and exposes the proposed and chosen transforms and the Diffie-Hellman group. **ESP** (Encapsulating Security Payload, IP protocol 50) then carries the protected data. Each ESP packet has the layout SPI | Sequence | IV | Encrypted(payload | padding | pad length | next header) | ICV.

3.2 Concepts Used by the Analyzer

- **ESP cipher geometry:** block ciphers pad the encrypted part to the block size B, so every packet length of one SA satisfies a congruence determined by B,

the IV size and the ICV size. Residues modulo 16, 8 and 4 separate AEAD/counter modes, 128-bit CBC and 64-bit CBC without any key.

- **PFS inference:** the size of the encrypted CREATE_CHILD_SA request grows by about 8 bytes plus the KE payload when a fresh Diffie-Hellman exchange is included, which reveals PFS and the most likely group.
- **Traffic analysis:** encryption hides content but not the shape of traffic; per-direction size percentiles, inter-arrival statistics, burstiness and periodicity identify the application class.
- **Conformal prediction:** wraps the classifier so that it outputs a set of labels with a calibrated coverage guarantee (90 % target) instead of a single over-confident label.
- **Metadata Exposure Index (MEI):** one minus the normalised entropy of the classifier's output; 1 means the application class is fully readable from ESP sizes and timings.

3.3 Literature and Technical Survey

Standard / Work	Relevance	Use in NUNMATHI
RFC 7296 (IKEv2)	Exchanges, payloads, rekeying, PFS	IKE decoder, rekey and PFS inference, NM-130
RFC 4303 (ESP)	ESP packet format and TFC padding	Geometry solver, NM-150 remediation
RFC 8221 / RFC 8247	Algorithm MUST / SHOULD NOT lists for ESP and IKEv2	Rules NM-110 to NM-122
RFC 9370 + ML-KEM (FIPS 203)	Hybrid post-quantum key exchange	ADDITIONAL_KEY_EXCHANGE detection
RFC 9395	Deprecation of IKEv1	NM-100 / NM-101
RFC 7383, RFC 3948, RFC 8019	IKE fragmentation, NAT-T, DoS protection	NM-161, NM-162, NM-160
NIST SP 800-77r1, SP 800-57	IPsec deployment guidance, key strength	Lifetimes (NM-131/132), DH strength
Sweet32 (CVE-2016-2183)	Birthday attack on 64-bit blocks	NM-121
Encrypted traffic classification literature	Application inference from size and timing	AI traffic classifier and MEI

4. System Design and Development

4.1 Architecture Overview

NUNMATHI is a **passive** pipeline. A capture file, a live packet stream or a generated testbed capture enters a six-stage engine that runs in-process inside the desktop application. The engine never sends packets, never holds keys and never decrypts; results are stored locally in SQLite and presented in a native window, in reports and as machine-readable JSON (Figure 1).

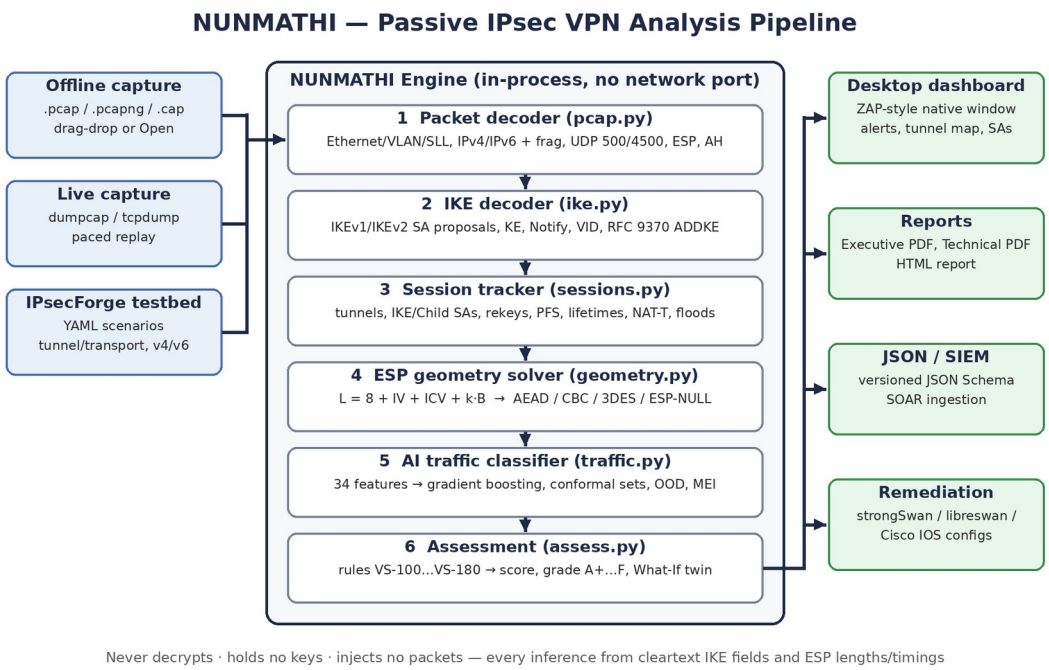


Figure 1: NUNMATHI system architecture

4.2 Components

4.2.1 Capture Inputs

- **Offline:** .pcap, .pcapng and .cap files opened from the File menu, by drag-and-drop or through the operating system's Open-with entry.
- **Live mode:** a real-time stream from dumpcap or tcpdump; new tunnels, rekeys, grade changes and alerts are reported as they happen while the stream is recorded to disk.
- **IPsecForge testbed:** YAML-described scenarios (tunnel/transport, AES-128/256, GCM, CBC+HMAC, DH groups, PFS on/off, IPv4/IPv6, traffic mixes) that produce standards-conformant captures with ground truth.

4.2.2 Protocol Decoders

The packet layer handles Ethernet, VLAN, Linux SLL/SLL2, raw IP and loopback, IPv4/IPv6 with fragment reassembly, UDP 500/4500 with the NAT-T non-ESP marker, ESP and AH. The IKE decoder parses IKEv1 and IKEv2 headers and payloads: SA proposals and transforms, KE, Nonce, ID, Vendor ID, Notify (including RFC 9370 ADDITIONAL_KEY_EXCHANGE) and encrypted/fragmented SK payloads.

4.2.3 Session Tracker

Pairs peers into tunnels, tracks IKE SAs by SPI and Child SAs by ESP SPI, and detects rekeys, IKEv2 re-authentication, half-open IKE floods, NAT traversal and Dead Peer Detection. It infers PFS and SA lifetimes; when a capture contains no rekey, lifetimes are reported as lower bounds.

4.2.4 ESP Geometry Solver

For every Child SA, the solver tests each cipher hypothesis against every observed packet length and produces a proof table (hypothesis, block/IV/ICV, claim, verdict, reason). Hypotheses that the data cannot separate are reported together, for example "AES-GCM-16 / ChaCha20-Poly1305". ESP-NULL is detected directly from the cleartext inner IP header.

4.2.5 AI Traffic Classifier

ESP packets are cut into 5-second windows; 34 features are computed after subtracting the inferred ESP overhead, so one model works for AEAD and CBC tunnels. A HistGradientBoosting classifier (250 iterations, 31 leaves) predicts voip, video, web, chat or e-mail, wrapped in split-conformal prediction and a 5-nearest-neighbour out-of-distribution detector.

4.2.6 Assessment, What-If Twin and Reporting

21 rules (NM-100 to NM-180) produce OWASP-ZAP-style alerts, a numeric score and a letter grade. The What-If twin re-scores a tunnel under proposed changes (IKEv2, PQ hybrid, PFS, stronger groups) and generates strongSwan, libreswan and Cisco IOS configuration. Reports are produced as an Executive PDF (2-3 pages), a Technical PDF (15-30 pages), HTML and JSON with a versioned schema for SIEM/SOAR.

4.2.7 Desktop Application

The user interface (React 19, ZAP-style layout with Sites tree, tabbed workspace and Alerts/History panes) runs in a native window: Qt WebEngine on Linux and WebView2 on Windows through pywebview. The FastAPI engine is called in-process through a bridge, so no HTTP server or network port is opened. The application detects missing GPU/OpenGL support and falls back to software rendering, and it ships as a Windows installer (about 75 MB) and a Debian package (about 180 MB).

4.3 Software and Algorithms

The two central inference steps are the key-less cipher geometry test and the scoring model:

ESP length congruence: $L = 8 + IV + ICV + k \cdot B \quad (k \in \mathbb{N}, B = \text{cipher block size})$

Metadata Exposure Index: $MEI = (\log_2 K - H(p)) / \log_2 K, \quad K = 5 \text{ classes}$

Tunnel score: $S = \max(0, 100 - 25 \cdot N_{High} - 10 \cdot N_{Medium} - 3 \cdot N_{Low})$

Grade: A+ ≥ 97, A ≥ 90, B ≥ 75, C ≥ 60, D ≥ 40, else F; any High caps at C, ≥ 3 High → F

A hypothesis is rejected by a single length that violates its congruence. When a Child SA carries only one or two distinct lengths (for example a constant-bitrate voice call) and more than one block size fits with a spurious-fit probability of at least 5 %, the SA is labelled **Ambiguous** and all alternatives are listed, so the tool never over-claims. Alert confidence (Confirmed, Firm, Tentative) is derived from the strength of the underlying evidence.

5. Development and Validation Flow

1. **Phase 1: Protocol decoding:** implemented link-layer, IP, UDP-encapsulation, IKEv1/IKEv2 and ESP/AH decoders; verified against tshark on forged captures with 0 malformed packets.
2. **Phase 2: Synthetic capture forge:** built IPsecForge to write standards-conformant IKE and ESP captures with ground-truth JSON, used for demos, training and regression tests.

3. **Phase 3: Inference engines:** developed the ESP geometry solver, PFS and lifetime inference, and the rule base with scoring.
4. **Phase 4: AI classifier:** trained on 3,508 synthetic windows with randomised ESP geometries, calibrated on 1,179 and tested on 1,174 independent windows: accuracy 0.994, macro-F1 0.9942, conformal coverage 0.994.
5. **Phase 5: Real-tunnel validation:** captured real tunnels between two strongSwan 6.0.7 gateways in isolated Linux network namespaces, with labelled application traffic, and compared every inference with the known gateway configuration.
6. **Phase 6: Productisation:** native desktop application, live mode, reports, JSON schema, Windows and Debian installers, and a 52-test automated suite covering offline/live parity.

Real tunnel (strongSwan 6.0.7)	What NUNMATHI inferred	Grade
IKEv2 AES-GCM-256 / ECP-384 + ML-KEM-768	Crypto and ML-KEM decoded, PFS (ECP-384), Child SA 30 s, IKE 85 s	A+
IKEv2 AES-CBC-128 / SHA-256 / MODP-2048, no PFS	ESP "128-bit CBC + 96-bit ICV", PFS disabled	B
IKEv1 Aggressive PSK, 3DES / SHA-1 / MODP-1024	64-bit block ESP, MODP-1024 and Aggressive PSK flagged	F
IKEv2 with ESP-NULL	Cleartext inner headers found (NM-120)	F

On the real tunnels the traffic classifier reached **98.8 %** top-1 accuracy on 82 labelled windows and **100 %** on 38 windows of a second, independently recorded traffic profile.

6. Final System Working

1. **Stage 1: Capture:** the analyst opens a capture, starts a live capture on an interface, or generates one from a testbed scenario.
2. **Stage 2: Decoding:** frames are decoded; IKE messages and ESP packets are extracted per peer pair.
3. **Stage 3: Session reconstruction:** tunnels, IKE SAs and Child SAs are built; rekeys, re-authentication, NAT-T and floods are detected, and the IKE message ladder is drawn.
4. **Stage 4: Cryptographic inference:** negotiated algorithms are read from IKE; ESP geometry, PFS and lifetimes are inferred with a proof for each conclusion.
5. **Stage 5: Traffic intelligence:** 5-second windows are classified into application types with conformal sets, OOD flags and the MEI.
6. **Stage 6: Assessment:** rules raise alerts with evidence and references; each tunnel gets a score, a grade and a threat matrix, with an overall AI-confidence summary.
7. **Stage 7: Remediation and reporting:** the What-If twin shows the improved grade and emits vendor configuration; Executive/Technical PDF, HTML and JSON reports are exported for management and SIEM/SOAR.

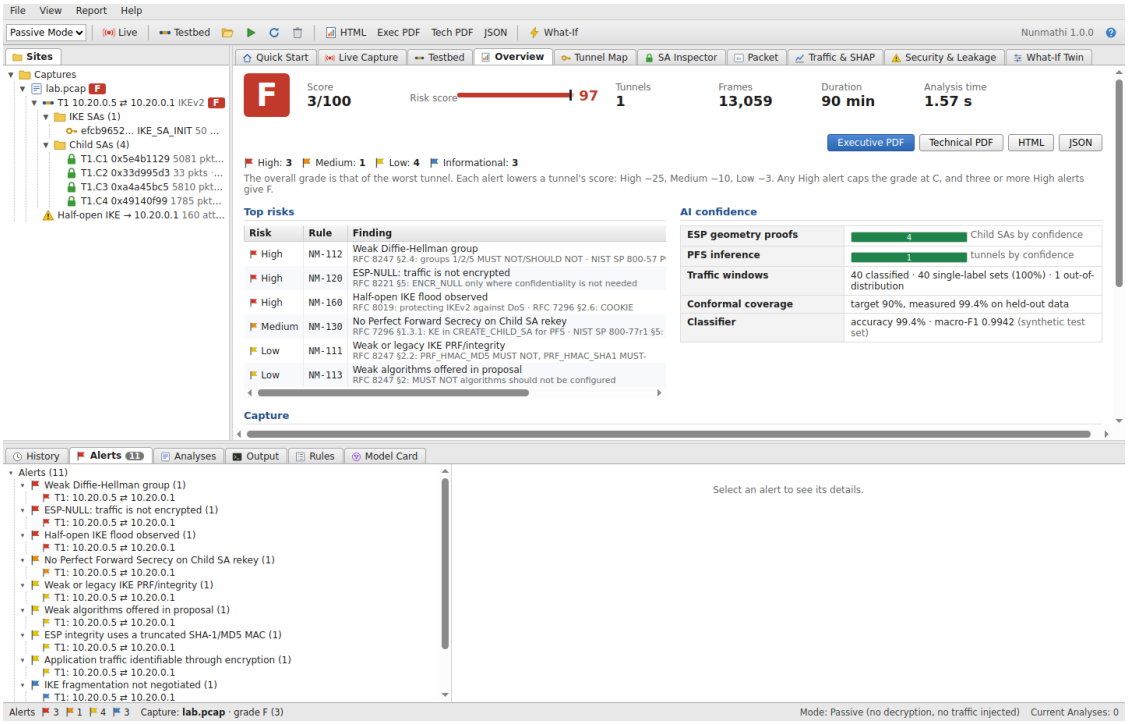


Figure 2: NUNMATHI desktop application, overview of a misconfigured tunnel (grade F)

7. Impact

7.1 National Security Impact

Gives NTRO and sector CERTs a way to audit VPN links of ministries, defence establishments and critical-infrastructure operators from traffic alone, without requesting gateway credentials or touching production devices. Weak key exchange, ESP-NULL and missing PFS are found before an adversary exploits them, and post-quantum readiness can be measured across an estate.

7.2 Operational Impact

A multi-hour manual review of packet dissections and configuration files becomes a graded report within seconds (a 90-minute, 13,000-frame capture is analysed in about 1.5 s). Live mode turns the analyzer into a monitoring sensor that reports rekeys, grade changes and new alerts as they happen.

7.3 Strategic Impact

An indigenous, offline, open-standards tool reduces dependence on foreign commercial VPN auditing products, and its JSON schema lets it feed national SOC platforms. The metadata exposure measurement informs policy on traffic-flow confidentiality for sensitive links.

8. Benefits

8.1 Technical Benefits

- **Key-less:** no decryption, no credentials, no packets injected; safe for production and third-party links.

- **Evidence-based:** every conclusion has a proof or evidence trail and an explicit confidence level.
- **Broad coverage:** IKEv1 and IKEv2, IPv4 and IPv6, tunnel and transport mode, NAT-T, fragmentation, RFC 9370 hybrid PQ.

8.2 Operational Benefits

- **Standalone:** a single native application installed from an .exe or .deb; works fully air-gapped.
- **Familiar workflow:** OWASP-ZAP-style interface with Sites tree, alerts, history and one-click reports.
- **Direct remediation:** generated strongSwan, libreswan and Cisco IOS configurations with a verify loop.

8.3 Economic Benefits

Built entirely on open-source components with no licence fees and ordinary laptops as the only hardware; the testbed removes the need for dedicated VPN appliances during training and evaluation.

8.4 Educational and Research Benefits

The testbed, geometry proofs, IKE ladder diagrams and model card make the tool a teaching platform for IPsec internals and encrypted-traffic analysis, and the forge provides labelled data for further research.

9. Technical Challenges and Engineered Solutions

Challenge	Impact	Engineered solution
Payload is encrypted and keys are unavailable	Cipher and integrity algorithm of ESP cannot be read	Length-congruence geometry solver with per-hypothesis proofs and equivalence classes
IKEv2 hides later exchanges in SK payloads	PFS on rekey not directly visible	Size-differential inference on CREATE_CHILD_SA with the negotiated geometry
Constant-size traffic (voice)	Too few distinct lengths to decide the block size	"Ambiguous" label with spurious-fit probability and all alternatives listed
Different ESP overheads per tunnel	Classifier features shift between AEAD and CBC	Overhead normalisation and training over randomised geometries
Synthetic-to-real gap	First model scored 0.46 on real traffic	Widened generators (UDP video, plain HTTP, CBR codecs); re-validated on a held-back real profile (1.000)
Over-confident ML output	Misleading single-label verdicts	Split-conformal prediction sets, OOD detection and MEI
Mid-session live captures	Missing IKE_SA_INIT and partial SAs	Unknown-aware reporting, lower-bound lifetimes, offline/live parity tests

Challenge	Impact	Engineered solution
Desktop deployment on varied hardware	Blank window without GPU/OpenGL; missing WebView2	OpenGL probe with software-rendering fallback; WebView2 check in installer and at start-up

10. Compliance, Standards and SDG Alignment

10.1 Standards Compliance

- **IETF:** RFC 7296, 4303, 8221, 8247, 9370, 9395, 7383, 3948, 8019 are encoded directly into the rule base with references in every alert.
- **NIST:** SP 800-77r1 (IPsec VPN guidance) and SP 800-57 (key strength); ML-KEM per FIPS 203.
- **Indian guidelines:** supports CERT-In audit requirements and NCIIPC protection practice for critical information infrastructure by producing evidence-based, exportable audit records.
- **Privacy:** passive by design; live captures keep only the first 64 bytes of ESP payload with the true length, and all data stays on the analyst's machine.

10.2 SDG Alignment

- **SDG 9: Industry, Innovation and Infrastructure:** secures the communication backbone of digital and critical infrastructure.
- **SDG 16: Peace, Justice and Strong Institutions:** strengthens the cyber resilience of government institutions and national security agencies.
- **SDG 4: Quality Education:** the testbed and explainable outputs support cybersecurity training.

11. References & Comparison

11.1 Comparison with Conventional Approaches

Capability	Conventional (Wireshark / manual config audit)	NUNMATHI
Access needed	Packet capture plus gateway configs or credentials	Packet capture only
ESP algorithm without keys	Not possible	Inferred from length geometry with proof
PFS and SA lifetimes	Manual reading of configs	Inferred from rekeys automatically
Security verdict	Analyst judgement	21 rules, score and A+…F grade with references
Encrypted traffic insight	None	AI classification, conformal sets, MEI
Post-quantum readiness	Manual	RFC 9370 / ML-KEM detection

Capability	Conventional (Wireshark / manual config audit)	NUNMATHI
Remediation	Written by hand	What-If twin with strongSwan / libreswan / Cisco configs
Reporting and SOC integration	Screenshots and notes	Executive and Technical PDF, HTML, versioned JSON
Time for a 90-minute capture	Hours	About 1.5 seconds

11.2 Methodology Workflow

Capture (offline / live / testbed) → Decode → Reconstruct sessions → Infer cryptography (IKE + ESP geometry + PFS) → Classify traffic (AI + conformal) → Assess and grade → What-If remediation → Report (PDF / HTML / JSON)

11.3 References

[1] C. Kaufman et al., "Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 7296, IETF, 2014.

[2] S. Kent, "IP Encapsulating Security Payload (ESP)," RFC 4303, IETF, 2005.

[3] P. Wouters et al., "Cryptographic Algorithm Implementation Requirements and Usage Guidance for ESP and AH," RFC 8221, IETF, 2017.

[4] Y. Nir et al., "Algorithm Implementation Requirements and Usage Guidance for IKEv2," RFC 8247, IETF, 2017.

[5] C. Tjhai et al., "Multiple Key Exchanges in the Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 9370, IETF, 2023.

[6] P. Wouters, S. Prasad, "Deprecation of the Internet Key Exchange Version 1 (IKEv1) Protocol and Obsoleted Algorithms," RFC 9395, IETF, 2023.

[7] V. Smyslov, "IKEv2 Message Fragmentation," RFC 7383, IETF, 2014.

[8] NIST, "Guide to IPsec VPNs," Special Publication 800-77 Rev. 1, 2020.

[9] NIST, "Module-Lattice-Based Key-Encapsulation Mechanism Standard," FIPS 203, 2024.

[10] K. Bhargavan, G. Leurent, "On the Practical (In-)Security of 64-bit Block Ciphers (Sweet32)," ACM CCS, 2016.

[11] V. Vovk, A. Gammerman, G. Shafer, "Algorithmic Learning in a Random World," Springer, 2005 (conformal prediction).

[12] G. Draper-Gil et al., "Characterization of Encrypted and VPN Traffic Using Time-Related Features," ICISSP, 2016.